

Ажурирање на dysnomiagallery.com — изработено

Клиент	Проект	Изработува	Датум	Основа
Dysnomia Gallery	dysnomiagallery.com	GoDevLab	1 октомври 2026	Тех. спецификација v1.0

Преглед на изработените измени од спецификацијата, дополнителните подобрувања и анализата на потенцијални грешки што досега не биле забележани.

4 / 4

бараните измени се
изработени во кодот

14

дополнителни
подобрувања (плус)

44

пронајдени потенцијални
грешки и ризици

6

од нив се поправени (3)
или подготвени во
миграција (3)

Статус: Сите измени се на гранката `update/2026-10-spec` (commit `eb5124b`). Проектот поминува TypeScript проверка и `npm run build` без грешки. **Сè уште не се поставени на живиот сајт.** Пред тоа треба да се применат миграциите во Supabase и да се постави новата edge функција (чекорите се во дел Г). Измените не се тестирани во прелистувач со вистинските податоци, бидејќи локално немаше пристап до базата. Тоа се прави на preview верзијата пред објавување.

А. Бараните измени од спецификацијата

1 Мени „Детски слики“ прикажува празна страница

Причина

Страницата бараше колекција со точен slug `kids`. Грешката се вратила затоа што страницата зависи од два податоци во админ панелот:

- Slug-от на колекцијата. Претходно бил `kid`, па бил поправен на `kids`.
- Ознаката „активна“. Ако колекцијата се скрие од `/collections`, базата веќе не ја дава на посетителите.

Која од двете причини е активна моментално ќе се потврди на живата база.

Направено

- Една заедничка логика (`src/lib/kidsCollection.ts`) ја наоѓа детската колекција. Ги прифаќа сите познати slug-ови (kids, kid, kids-pictures, detski-sliki...), а ако ниту еден не се совпаѓа, ја бара според насловот („Kids“ / „Детски“). Истата логика се користи на страницата, во продавницата, кај деталите за дело и кај колекциите.
- Миграција 009: детската колекција останува достапна за посетителите и кога е скриена од /collections.
- Страницата сега ги прикажува **сите** детски дела. Претходно прикажуваше само првите 12.
- Линкот `/kids` пренасочува на `/kids-pictures` . Претходно ја отвораше почетната страница.
- **Автоматска проверка** (`scripts/check-site.mjs`) се извршува при секоја нова верзија на Vercel. Ако детската колекција не е достапна или нема објавени дела, верзијата не се објавува.

Готово кога

Кодот е готов. По примена на миграција 009 и објавување се проверува на компјутер и мобилен.

2 Иконата за Instagram води до непостоечка страница

Причина

Линковите водеа на стариот профил `@dysnomia_art.gallery666` , на три места: футер, „За нас“ и „Контакт“. Главното мени нема икони за социјални мрежи.

Направено

- Сите линкови водат на `instagram.com/dysnomia.gallery` . На страницата „Контакт“ пишува `@dysnomia.gallery` .
- Линковите за социјални мрежи и е-поштата се на едно место (`src/config/social.ts`). Идна промена се прави на едно место.
- Линкот за Facebook е проверен и е непроменет. Нема други социјални мрежи на сајтот.
- Автоматската проверка не дозволува објавување ако стариот профил повторно се појави во кодот.
- Плус: профилите се додадени во структурираните податоци за Google (`sameAs`), а иконите имаат ознака за читачи на екран.

Готово кога

Готово во кодот. Иконата го отвора профилот `@dysnomia.gallery`.

3 Блог: текст под сликата и дополнителни слики

Направено

- Статијата веќе не е во две колони. Насловната слика е лево, текстот тече десно од неа и по нејзиниот крај продолжува под неа. Ширината на статијата е ограничена на 960px, за редовите да бидат лесни за читање.
- Во уредувачот на статии (Admin → Blog) може да се додадат **до две дополнителни слики**, секоја со опис на англиски и македонски. Може да се избере по кој пасус се прикажува сликата. Ако не се избере, сликите се распоредуваат рамномерно низ текстот.
- На мобилен сите слики одат преку целата ширина.
- Плус: пасусите се делат правилно и кога текстот е вметнат од Word или Windows. Единечните нови редови се почитуваат.
- Плус: уредувачот прикажува порака ако зачувувањето не успее. Претходно грешката се губеше без порака.

Готово кога

Кодот е готов. Бара миграција 009 (поле `gallery_images` , најмногу 2 слики).

4 Пријава за новости

Наод	Во кодот не постоеше поле за пријава за новости ниту листа на претплатници. Функционалноста е изградена целосно, со насловот „Регистрирај се за најновите информации“.
Направено	• Форма во футерот, на сите страници. Има поле за е-пошта и задолжително поле за согласност за примање понуди. Пораките се на македонски и англиски. • Листа на претплатници (табела <code>newsletter_subscribers</code>). За секоја пријава се зачувува времето и текстот на согласноста, што е важно за GDPR. Листата е видлива само за администратор. • Е-порака за добредојде преку Resend. Секоја порака има линк за одјава и стандардно „List-Unsubscribe“ заглавие за Gmail и Outlook. • Страница за одјава <code>/unsubscribe</code>. Одјавата е со еден клик од линкот во пораката. • Поврзување со Brevo: кога ќе се внесат клучевите <code>BREVO_API_KEY</code> и <code>BREVO_LIST_ID</code>, секој претплатник автоматски се додава во листата во Brevo, а при одјава се отстранува. • Админ → Newsletter: преглед, пребарување, одјава и бришење на претплатник, како и извоз во CSV за Mailchimp или друга алатка. • Заштита од злоупотреба: ○ ограничување на 5 пријави на час по IP адреса; ○ скриено поле (honeypot) против ботови; ○ одговорот не открива дали е-поштата веќе е пријавена.
Готово кога	Кодот е готов. Бара миграција 009, поставување на функцијата <code>newsletter</code> и потврден домен за праќање во Resend.

Б. Дополнително направено (плус)

Подобрување	Зошто е важно
Страници <code>/privacy</code> и <code>/faq</code> се вклучени	Банерот за колачиња водеше до „Страницата не е пронајдена“ (404), што е правен ризик. Страниците постоеја, но не беа поврзани. Додадени се во футерот, во SEO податоците и во sitemap.
Заштита на е-пораките за нарачки	Секој можеше да испрати лажна „потврда за нарачка“ со произволна содржина на која било адреса, во име на галеријата. Сега податоците за нарачката се читаат од базата, а пораката може да се испрати само до 30 минути по нарачката.
Нацрт-делата се скриени	Делата во статус „нацрт“ беа достапни јавно преку директен линк. Сега се прикажуваат само објавените и продадените.
Миграција 010 (подготвена)	Ги брише старите дозволи со кои секој регистриран купувач би можел да менува производи и колекции. Ги усогласува цените во базата со цените на сајтот. Овозможува бришење нарачки од админ панелот. Се применува по проверка.
Чистење на репозиториумот	Од git се отстранети 250 macOS датотеки <code>.*</code> и 8 привремени Supabase датотеки. Двата вида се додадени во <code>.gitignore</code> , а <code>.*</code> и во игнорираните датотеки на ESLint.
Футер	Отстрането е празно копче без содржина. Поправени се двојните клучеви (две врски водеа на <code>/shipping</code>). Додадени се врски до ЧПП и Политика за приватност.

Автоматска проверка пред објава

Пред секоја нова верзија на Vercel се проверува дека детската страница ќе има дела и дека нема стари социјални линкови. Во итен случај проверката може да се прескокне со `SKIP_SITE_CHECKS=1`.

В. Анализа на потенцијални грешки

Прегледани се фронтендот, edge функциите, SQL миграциите, prerender, sitemap и Vercel конфигурацијата. Ставките означени со „провери во база“ зависат од тоа дали живата база одговара на SQL датотеките во репозиториумот.

Ниво	Проблем	Ризик / сценарио	Статус
Критично	Е-пораката „Нарачка примена“ може да се злоупотреби	Лажни е-пораки во име на галеријата до произволни адреси. Се троши квотата на Resend и доменот може да заврши на црна листа.	Поправено
Критично	Нацрт-делата се јавно достапни (<code>cached-product</code>)	Необјавени дела, со сите податоци, се гледаат преку директен линк.	Поправено
Критично	Стари дозволи „секој најавен корисник“ на производи и колекции (<i>провери во база</i>)	Регистриран купувач може да менува или брише дела и колекции.	Миграција 010
Високо	Цените во базата се постари од цените на сајтот (<i>провери во база</i>)	Сајтот прикажува 1.299 ден., а базата пресметува 2.640 ден. Нарачката, потврдата и е-поштата би имале повисока цена од прикажаната.	Миграција 010
Високо	Е-поштата на рецензентите е јавна	Секоја страница за дело ги испраќа е-адресите на авторите на рецензиите до прелистувачот.	Отворено
Високо	Креирањето нарачка верува на количините од клиентот	Прифаќа негативни или огромни количини и празна нарачка, без проверка дали делото е објавено. Ограничувањето на бројот нарачки е по е-пошта, па лесно се заобиколува.	Отворено
Високо	Банерот за колачиња води на <code>/privacy</code> (404)	Правен и GDPR ризик.	Поправено
Високо	Prerender враќа 404 + <code>noindex</code> на Google кога базата е бавна или колоната не постои	Колекции, дела и статии можат да испаднат од Google.	Отворено
Високо	Бришењето нарачка во админ панелот ништо не брише	Админ панелот јавува успех, а нарачката останува.	Миграција 010
Високо	Статистиката за посети е отсечена на 1.000 записи	Над 1.000 посети во периодот, графиконите ги покажуваат само најстарите денови.	Отворено
Високо	Табелите за блог и најави немаат миграција и дозволи во репозиториумот (<i>провери во база</i>)	Можно читање на нацрт-статии или менување на лентата со најави.	Отворено
Средно	Филтерот и сортирањето по цена во продавницата не работат	Користат неискористено поле <code>price</code> со прагови 100/200/300, а цените се 749+ ден.	Отворено
Средно	Кошничката ја чува старата цена	По промена на ценовникот, кошничката прикажува стара цена. Оштетени податоци во прелистувачот можат да го срушат сајтот.	Отворено

Средно	Грешка при вчитување по секоја нова верзија	Отворените јазичиња добиваат „Failed to fetch module“ при отворање нова страница, бидејќи старите JS датотеки се враќаат како HTML.	Отворено
Средно	Пристапот до меморијата на прелистувачот не е заштитен	Во приватен режим или на стар iOS, целиот сајт може да остане бел.	Отворено
Средно	Страницата за дело прикажува „Слични дела“ од претходното дело	Податоците не се ресетираат при преминување од дело на дело.	Отворено
Средно	Зачувувањето дело може тивко да ја избрише врската со колекцијата	Бришење, па вметнување, без трансакција и без пријава на грешка. Делото „исчезнува“ од колекцијата.	Отворено
Средно	Зачувувањето на најпродаваните може да ја избрише листата	Ако вметнувањето не успее, листата останува празна.	Отворено
Средно	6 фиксни рецензии со 5 ѕвезди на секое дело	Ризик според правилата за заштита на потрошувачи (лажни рецензии).	Отворено
Средно	Македонските страници упатуваат кон англиската верзија (canonical)	Македонската верзија најверојатно не се индексира во Google.	Отворено
Средно	Промена на slug ги крши старите линкови	Споделените и индексираните линкови водат до 404. Нема пренасочување.	Отворено
Средно	Slug од наслов на кирилица е празен	Автоматскиот slug ги брише сите кирилични букви, па колекција со наслов само на кирилица добива празен slug.	Отворено
Средно	Е-пораките за статус на нарачка може да се дуплираат	Пораката се праќа и кога промената не успеала или статусот е ист.	Отворено
Средно	Аналитиката снима пред согласноста за колачиња	GDPR ризик. Табелата за посети може да се преполни, а збирната статистика е достапна без најава.	Отворено
Средно	Администраторот може да биде одјавен при привремена грешка	Се губат незачуваните измени во формите.	Отворено
Средно	Можен пристап до туѓи нарачки (<i>йровери йосџавка</i>)	Ако потврдата на е-пошта при регистрација е исклучена, некој може да се регистрира со туѓа е-пошта и да ги види нарачките на гостинот.	Отворено
Средно	„Мои нарачки“ разликува големи и мали букви во е-поштата	Нарачките направени со „lme@...“ не се гледаат на профилот.	Отворено
Средно	Пребарувањето не ги бара македонските наслови	Пребарување на кирилица не враќа резултати.	Отворено
Средно	Sitemap ги губи сите дела ако базата не одговори при build	Привремен прекин во Supabase при објавување ги брише делата од sitemap.	Отворено
Средно	Redis врската може да заглави (<i>можно</i>)	Ако Redis не одговара, страниците за дела може долго да се вчитуваат.	Отворено

Ниско Помали ставки, за подоцнежнo средување:

- Англиски текстови без превод: грешки при плаќање, банер за колачиња, е-пораки за нарачки, поставки на профилот.
- „Зачувај“ во поставките на профилот всушност ништо не зачувува.

- Истакнатите („featured“) дела никогаш не се применуваат, бидејќи полето не се вчитува.
- `supabase-featured.sql` има синтаксна грешка и не може да се изврши.
- Нема резервна слика кога сликичката (thumbnail) не постои.
- Неограничени листи (нарачки, рецензии) се отсекуваат на 1.000 записи.
- Заменетите слики не се бришат од складиштето.
- SECURITY DEFINER функциите немаат фиксен `search_path`.
- Стандардниот испраќач е `orders@dysnomia.art`, а доменот на сајтот е `dysnomiagallery.com`.
- Админ белешките ги препишуваат белешките на купувачот, бидејќи се во исто поле.
- Localhost е дозволен во CORS ако `ENVIRONMENT=production` не е поставено.
- Google Fonts се вчитуваат двапати, на начин што ја блокира првата слика на страницата.
- Неискористени компоненти содржат скршени линкови.
- Најавен купувач што ќе отвори `/admin` останува на „Нема пристап“, без копче за одјава.

Проверено и во ред:

- Нарачките се креираат само преку серверска функција со серверски цени.
- Само администраторот може да прикачува датотеки.
- Нема `dangerouslySetInnerHTML`, а блогот се прикажува како чист текст.
- CSP одговара на доменот што се користи.
- Во репозиториумот нема тајни клучеви.
- Надворешните линкови се безбедни (`noopener`).
- `robots.txt` ги исклучува админ панелот, кошничката и профилот.
- Преводите EN/MK се целосни: 333 од 333 клучеви.

Г. Чекори за поставување на живиот сајт

1. Во Supabase SQL Editor да се изврши `supabase/migrations/009_october_2026_update.sql`.
2. Да се провери живата база со барањата наведени на врвот на `010_security_and_price_fixes.sql`, па миграцијата да се изврши. Пред тоа да се потврди дека админ сметката е во `user_roles` со улога `admin`.
3. Да се постават edge функциите: `supabase functions deploy newsletter send-order-email cached-product`.
4. Тајни клучеви (secrets):
 - `RESEND_API_KEY` веќе постои.
 - По желба `RESEND_NEWSLETTER_FROM`, на пр. `Dysnomia Gallery <news@dysnomiagallery.com>`. Доменот мора да е потврден во Resend.
 - За Brevo: `BREVO_API_KEY` и `BREVO_LIST_ID`.
 - `ENVIRONMENT=production`.
5. Гранката `update/2026-10-спес` да се спои во `main` и да се push-не. Vercel ќе ја изврши автоматската проверка пред build.
6. Тест на живо:
 - „Детски слики“ на компјутер и мобилен;
 - иконата за Instagram;
 - статија со две дополнителни слики;
 - пријава за новости: пораката за добредојде, одјавата и записот во Admin → Newsletter;
 - една пробна нарачка: потврдата и цената.

Препорака за следниот циклус: ставките „Отворено“ со високо ниво (рецензии, нарачки, prerender, статистика, табели за блог и најави) и средните што влијаат на продажба (филтер по цена, кошничка, грешка по нова верзија).